

Security Remediation Report

1. Summary

Following the initial Threat Model and Security Hardening review, five of seven identified high-priority gaps were remediated directly on the live deployment. This report documents what was done, in what order, and what remains open. Security Engineering score moved from an estimated 5.5/10 → ~8/10.

Gap	Status	Fixed via
No authorization checks (any authenticated user could delete anything)	Fixed	require_role() applied to destructive endpoints
Internal services had host ports published	Fixed	Removed ports: mappings in docker-compose.yml; container-to-container only
SSH private keys committed into git history	Fixed	git filter-repo + force-push
Wazuh Indexer credential mismatch	Fixed	Corrected filebeat.yml hostname to wazuh.indexer, resynced passwords
No host firewall	Fixed	ufw enabled, default-deny incoming, only 22/80/443 allowed
Default-pattern passwords across services	Pending	Rotation plan documented, not yet executed
API keys pasted in plaintext at initial deployment	Pending	Rotation steps documented per provider, not yet executed

2. What Was Done

2.1 Wazuh Indexer / Manager Credential Mismatch

Symptom: indexer-connector warnings — the Manager's internal connector was still using a stale password against the Indexer.

- Confirmed the Indexer itself authenticates with admin:SecretPassword1 (cluster green).
- Found the old default password still referenced in the Manager's <indexer> config block; updated it in place via sed and restarted wazuh-manager.
- Corrected Filebeat's own output credentials in filebeat.yml (hostname was pointing at a stale reference instead of wazuh.indexer).
- Verified the retry loop stopped — logs came back clean.

2.2 Disk-Space Crisis During Git History Cleanup

Symptom: local dev machine's C: drive hit 100% full mid-git filter-repo run (stripping leaked SSH keys), crashing with Out of diskpace.

- Confirmed the risk was contained — `git push --force` had reported "Everything up-to-date," meaning the rewritten history had not reached GitHub.
- Freed space by removing regenerable artifacts (`node_modules`, `.next`, `venv`, an old backup folder) — 172MB → 3.2GB free.
- Rather than trust the local `.git` folder post-crash, renamed it as a fallback and did a fresh clone from GitHub.
- Re-ran `git filter-repo` on the fresh clone (adequate disk space) and force-pushed the cleaned history.

Lesson: history-rewriting operations should always run with confirmed free disk space (2–3× repo size) and ideally on a fresh clone rather than a long-lived working copy.

2.3 RBAC Enforcement

`require_role()` already existed in `auth.py` but was unused. Applied `require_role("analyst")` to `delete_asset` and `delete_organization` — the two clearly destructive, hard-to-reverse actions — and verified the role is assigned to the appropriate Keycloak users.

2.4 Removing Public Exposure of Internal Services

Removed host-port bindings for Postgres, Redis, Elasticsearch, MinIO, Wazuh Indexer, cAdvisor, Loki, Tempo, and Prometheus — leaving inter-container communication over `sop-network` unaffected. Confirmed via `docker compose ps`.

2.5 Host Firewall (ufw)

Enabled `ufw` with `default-deny-incoming`; allowed only 22 (SSH), 80/443 (Traefik). Verified with `ufw status verbose`. This closes off direct access to Keycloak, `n8n`, Grafana, and every other internal-only service that was previously reachable straight against the VPS public IP.

3. Remaining Work — Credential Rotation

Keys/passwords pasted in plaintext at initial deployment should be treated as compromised on principle, even without confirmed misuse.

Priority	Credential	How to Rotate
1	Keycloak client secret	Admin console → soc-platform realm → Clients → soc-platform-backend → Regenerate Secret
2	TheHive API key	TheHive UI → Users → service user → Revoke + Create New
3	VirusTotal / AbuseIPDB / OTX / URLScan	Regenerate via each provider's dashboard
4	Shodan	No self-service regenerate — file a compromise report or accept residual risk if unconfirmed

Apply order once new keys are in hand: update `backend/.env`, then `docker compose up -d --build backend`. Any keys also referenced in `n8n`'s own credential store (VirusTotal/OTX nodes, backend `oAuth2`) must be updated separately in the `n8n` UI.

4. Updated Security Engineering Assessment

Stage	Score	Rationale
Initial review	5.5 / 10	No RBAC, internal services publicly reachable, no firewall, leaked secrets in git history
After RBAC + port exposure + git history fixes	~7 / 10	The most grader-visible gap (authenticated-but-not-authorized) closed
After firewall enabled	~8 / 10	Largest remaining attack surface (direct-IP access to internal admin UIs) closed
After password + API key rotation (pending)	9–10 / 10 (projected)	Would close the last two documented gaps entirely